

Clase 324 — Operaciones de seguridad: hardening y gestión de configuración

Parte: **17 — Profundización para certificaciones** · Fuente: *CompTIA Security+ (SY0-701)* — *Security Operations · (ISC)² CISSP OSG* — *Security Operations · CIS Benchmarks* ⌚ Duración estimada: **130 min** · Nivel: **Intermedio**

Objetivo

Reducir la superficie de ataque **antes** de que llegue el atacante. Esta clase cubre las operaciones de seguridad del día a día: establecer **baselines** con **CIS Benchmarks**, mantener la **gestión de configuración segura** (evitar la deriva/drift), operar un **programa de gestión de parches** con NIST SP 800-40, integrar la **gestión del cambio** para que el hardening no rompa el negocio, y aplicar **hardening de sistemas operativos y servicios**. Es el corazón de *Security Operations* en Security+ y CISSP.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

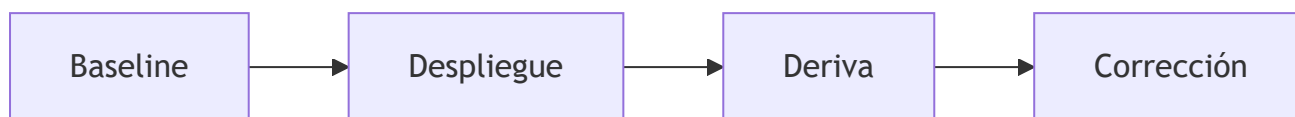
1. **Establecer** una baseline de seguridad a partir de un CIS Benchmark y medir cumplimiento.
2. **Detectar y corregir** la deriva de configuración (configuration drift) con gestión de configuración.
3. **Operar** un ciclo de gestión de parches con priorización, ventanas y validación (NIST SP 800-40).
4. **Integrar** el proceso de gestión del cambio (RFC, aprobación, rollback) con las operaciones de hardening.
5. **Aplicar** medidas de hardening de OS y servicios reduciendo la superficie de ataque de forma verificable.

Temas

#	Tema	Por qué importa
1	Baselines de seguridad	Definen el estado seguro conocido y auditable
2	CIS Benchmarks y niveles	Guías consensuadas y verificables por plataforma
3	Hardening de OS y servicios	Minimiza la superficie de ataque explotable
4	Gestión de configuración y drift	Mantiene el estado seguro en el tiempo
5	Gestión de parches (SP 800-40)	Cierra vulnerabilidades conocidas con orden
6	Gestión del cambio (RFC, CAB, rollback)	Cambia sin romper ni sorprender al negocio
7	Automatización (IaC, Ansible/GPO)	Hardening consistente y a escala
8	Monitoreo continuo de configuración	Verifica que la baseline se sostiene (SP 800-137)

Modelo mental y caso de decisión

Hardening define estado deseado, despliega, verifica deriva y gestiona excepciones; una imagen inicial no basta.



Caso razonado. Una excepción temporal queda permanente. Caducidad y dueño la devuelven a decisión.

Glosario operativo complementario

Término	Definición
Evidencia	Información cuya procedencia y relación con un criterio pueden revisarse.
Supuesto	Condición declarada de la que depende una conclusión.
Riesgo residual	Exposición que permanece después del tratamiento.

Criterio de dominio

El alumno demuestra dominio cuando explica el diagrama, resuelve el caso con evidencia, declara límites y puede defender por qué su decisión cambia si cambia un supuesto.

Definiciones y características

- **Baseline de seguridad:** conjunto mínimo y documentado de ajustes de configuración que define el estado "seguro conocido" de un sistema. Característica clave: es el punto de referencia contra el que se mide la deriva y el cumplimiento.
- **CIS Benchmark:** guía de hardening consensuada por la comunidad, específica por plataforma (Windows, Linux, navegadores, nube), con recomendaciones justificadas y verificables. Característica clave: define **niveles** —L1 (seguridad práctica sin romper funcionalidad) y L2 (defensa profunda para entornos sensibles).
- **Hardening:** proceso de reducir la superficie de ataque —desactivar servicios/puertos innecesarios, cerrar cuentas por defecto, aplicar mínimo privilegio, cifrar. Característica clave: menos funciones expuestas = menos vías de ataque.
- **Configuration drift (deriva):** divergencia gradual de la configuración real respecto de la baseline por cambios manuales no controlados. Característica clave: reintroduce riesgo silenciosamente; se combate con gestión de configuración y monitoreo.
- **Gestión de parches:** proceso de identificar, priorizar, probar, desplegar y verificar actualizaciones (NIST SP 800-40). Característica clave: no es "instalar todo ya"; prioriza por riesgo y valida antes de producción.
- **Gestión del cambio:** proceso formal (RFC → evaluación → aprobación del CAB → implementación → verificación → rollback si falla). Característica clave: cada cambio queda autorizado, documentado y reversible.
- **CAB (Change Advisory Board):** comité que evalúa y aprueba cambios según riesgo e impacto. Característica clave: separa la decisión de la ejecución y evita cambios sorpresa en producción.

- **Monitoreo continuo (ISCM):** verificación permanente de que la configuración sigue conforme (NIST SP 800-137). Característica clave: convierte el cumplimiento en un estado vigilado, no en una foto anual.

Herramientas y preparación

Entorno **de laboratorio propio** con máquinas de prueba (nunca producción sin autorización):

- **VM de prueba** (Windows Server o Ubuntu) aislada para aplicar y revertir cambios con snapshots.
- **CIS Benchmark** correspondiente (PDF gratuito) y, si está disponible, **CIS-CAT Lite** para evaluar cumplimiento automáticamente.
- **Herramienta de configuración:** Ansible/PowerShell DSC o GPO para aplicar el hardening de forma repetible.
- **Escáner de configuración:** OpenSCAP (perfiles SCAP) o Lynis en Linux para medir el estado.
- **Registro de cambios (RFC)** y plantilla de gestión del cambio con plan de rollback.

Nota operativa: aplica hardening **primero en laboratorio con snapshot**. Un ajuste mal medido puede dejar un sistema inaccesible; por eso existen la gestión del cambio y el rollback.

Laboratorio guiado — Aplicar un CIS Benchmark con gestión del cambio

Ejercicio aplicado: endureces una VM siguiendo un CIS Benchmark, controlando el proceso con gestión de configuración y del cambio.

1. **Toma la línea base actual.** En la VM aislada, ejecuta un escaneo inicial (CIS-CAT Lite, OpenSCAP o Lynis) y guarda el porcentaje de cumplimiento y los hallazgos. Haz un snapshot.
2. **Selecciona el benchmark y nivel.** Descarga el CIS Benchmark de la plataforma y elige nivel (L1 para un servidor de propósito general). Justifica por qué L1 y no L2.
3. **Abre un RFC.** Registra el cambio: qué recomendaciones se aplicarán, riesgo, ventana, plan de pruebas y **plan de rollback** (restaurar snapshot). Simula la aprobación del CAB.
4. **Aplica el hardening por lotes.** Implementa un grupo de recomendaciones (p. ej. políticas de contraseña, desactivar servicios innecesarios, cerrar puertos, deshabilitar cuentas por defecto) con Ansible/GPO/DSC —no a mano— para que sea repetible.
5. **Reescanea y compara.** Vuelve a medir el cumplimiento y confirma la mejora. Documenta qué recomendaciones no se aplicaron y por qué (excepciones justificadas).
6. **Prueba la funcionalidad.** Verifica que los servicios legítimos siguen operando. Si algo se rompe, ejecuta el rollback y ajusta la excepción: así se demuestra el valor de la gestión del cambio.
7. **Congela la baseline.** Guarda la configuración endurecida como la nueva baseline versionada (en el repositorio de configuración/IaC).
8. **Detecta drift.** Cambia manualmente un ajuste, vuelve a escanear y observa cómo el monitoreo detecta la deriva; corrígela reaplicando la configuración desde la fuente de verdad.
9. **Integra el parcheo.** Añade la evaluación de parches pendientes al ciclo: prioriza uno crítico, pruébalo en la VM y documenta la ventana de despliegue (SP 800-40).

Entregable: informe con cumplimiento inicial vs final, RFC con plan de rollback, lista de excepciones justificadas, evidencia de detección/corrección de drift y baseline versionada.

Ejercicios

1. Justifica cuándo elegir CIS nivel L1 y cuándo L2 para tres tipos de servidor.
2. Redacta un RFC completo (cambio, riesgo, ventana, pruebas, rollback) para desactivar SMBv1 en una flota.
3. Escribe una tarea de Ansible/GPO que aplique tres recomendaciones de hardening y sea idempotente.
4. Diseña un flujo de detección de drift: qué se escanea, cada cuánto y cómo se corrige.
5. Prioriza cinco parches por riesgo (CVSS + explotación + exposición) y define su ventana.
6. Documenta una excepción de baseline justificada y su compensación (control alternativo).

Reto verificable

Reto: entrega el paquete de hardening de una VM controlado por gestión del cambio, con evidencia de mejora y de control de drift.

Criterio de aceptación:

- Hay medición de cumplimiento **inicial y final** contra un CIS Benchmark, con mejora demostrada.
- El hardening se aplicó de forma **repetible** (Ansible/GPO/DSC/IaC), no manual, y la baseline quedó **versionada**.
- Existe un **RFC** con riesgo, ventana, pruebas y **plan de rollback**, más una lista de excepciones justificadas.
- Se **detectó y corrigió** al menos un caso de configuration drift desde la fuente de verdad.
- El ciclo incluye **gestión de parches** con priorización por riesgo y ventana documentada (SP 800-40).

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"Aplicué el benchmark y el sistema dejó de funcionar"	Endureciste sin probar. Usa snapshot, aplica por lotes y prueba funcionalidad antes de producción.
"Cada servidor está configurado distinto"	Hardening manual = deriva. Aplica desde una fuente de verdad (IaC/GPO) idempotente.
"Instalamos todos los parches de golpe y algo se rompió"	Falta priorización y prueba. Prioriza por riesgo y valida en laboratorio antes del despliegue.
"Cambié la config a mano y nadie se enteró"	Sin gestión del cambio hay drift invisible. Todo cambio pasa por RFC y queda registrado.
"El benchmark exige algo que rompe una app crítica"	No fuerces L2 donde no toca. Documenta una excepción con control compensatorio y aprueba el riesgo.
"Medimos cumplimiento una vez al año"	El cumplimiento se degrada. Implementa monitoreo continuo (SP 800-137) para vigilar la baseline.

? Preguntas frecuentes

? **¿CIS Benchmark nivel 1 o nivel 2?** L1 aplica controles prudentes que rara vez rompen funcionalidad y sirve como base para casi todo. L2 añade defensa en profundidad para entornos sensibles, a costa de posibles impactos de compatibilidad. Empieza en L1 y sube donde el riesgo lo justifique.

? **¿Debo aplicar todas las recomendaciones del benchmark?** No a ciegas. Cada recomendación se evalúa contra tu contexto; las que rompan operaciones legítimas se gestionan como excepción documentada con un control compensatorio, no se ignoran en silencio.

? **¿Cómo evito la deriva de configuración?** Definiendo la configuración como código (IaC/GPO/DSC) desde una fuente de verdad, aplicándola de forma idempotente y verificando continuamente con un escáner. Cuando aparece drift, se reaplica la configuración canónica.

? **¿Parchear rápido o parchear seguro?** Ambos, con prioridad por riesgo: los parches de vulnerabilidades explotadas activamente (KEV) van por vía rápida con pruebas mínimas; el resto sigue la ventana normal con validación. La gestión del cambio permite acelerar sin improvisar.

Referencias

-  **En la empresa:** gestión de parches con **Microsoft WSUS/SCCM (MECM)**, **Intune** o **Ansible**; verificación de baselines con **CIS-CAT** y benchmarks CIS.
- CompTIA. *Security+ (SY0-701) Exam Objectives* — dominio *Security Operations*.
- Chapple, Stewart & Gibson. *(ISC)² CISSP Official Study Guide*, 9.ª ed., Sybex — *Security Operations*.
- CIS. *CIS Benchmarks* y *CIS-CAT* — cisecurity.org/cis-benchmarks.
- NIST. *Guide to Enterprise Patch Management Planning* — [SP 800-40 Rev.4](#).
- NIST. *Information Security Continuous Monitoring (ISCM)* — [SP 800-137](#).

Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.

Clase anterior

[Clase 323 — Pruebas de seguridad del software y evaluación](#)

Siguiente clase

[Clase 325 — Forense de memoria avanzado](#)